

Security of age verification systems on the internet

Matt ter Steege

`m.j.tersteeg@students.uu.nl`
Univeriteit Utrecht, Utrecht, Nederland

Abstract.

1 Introduction

The internet was originally built around anonymity and unrestricted access. This means that online services had little to no reliable way of determining who their users actually were. The time that simple legislation came, websites were only required to use simple age “verification” methods that were easy to bypass.

Over the last decade, governments have started taking online child safety more seriously. Legislation such as COPPA (section 2) in the United States and the United Kingdom’s Online Safety Act 2023 introduced stricter requirements for online platforms regarding age-restricted content and services. This created a major technical problem: how can an online service verify the age of a user without collecting excessive personal data?

Modern age verification systems attempt to solve this problem through different technologies, ranging from AI-based age estimation using face scans to the European Union’s Age Digital Identity Wallet. The latter is one of the most ambitious attempts so far. One of its subsystems, the Age Verification System, promises privacy-preserving age verification through cryptographic techniques such as zero-knowledge proofs, while minimising personal data shared with on-line services.

This report explores the security and privacy aspects of online age verification systems, with a particular focus on the European Union’s Age Verification Solution. The report analyses traditional age verification and AI-based age estimation methods, and the technical architecture of the EU Age Verification App in the current implementation. Furthermore, several security weaknesses are examined, followed by a comparison with verification approaches used in the banking sector. Finally, the report proposes technical improvements and discusses the broader ethical and societal implications of large-scale digital identity systems.

2 Background

COPPA was one of the first notable bills that passed the US Congress in 1998 [9]. This law was put in place to make sure that parents are in control over what

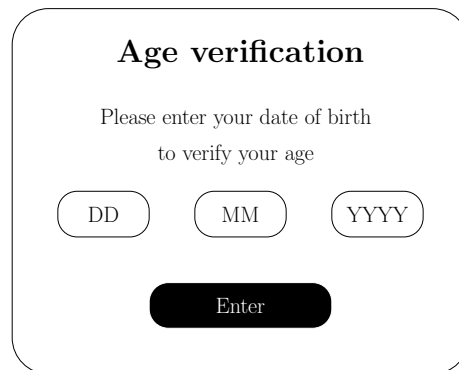
information is collected from their (young) child(ren) by online services that are targeted at children aged under 13. This law seeks to protect the information of children who are under 13 years old. Later on, this law was revised by COPPA 2.0, which passed the Senate, but (as of May 2026) has not been accepted by the House of Representatives [10].

Another bill that left a bigger mark on child safety is the UK’s Online Safety Act 2023. This act was partially created to prevent children from encountering harmful or age-inappropriate content and enforce strict age checks [11]. These sets of laws are regulated by Ofcom¹.

This, however, begs the question: how does one check if a user of an online service is actually past a certain age, albeit 13, 17, or 18 years old?

2.1 Traditional Age Verification

For a very long time, online services used methods that checked the age of users where not all that high-tech. Since most legislation was not all that strict on what was allowed to happen on the internet, it was not that hard to comply with. This gave rise to a couple of types of “verification” methods. These methods ranged from surface-level checks to more rigorous verification methods. One of the most well-known checks is the so-called “honour systems”, these age verification systems depend on the honesty of the end user. Most commonly, services ask for the date of birth (as seen in figure 1) of an end user or a simple “I am 18 years old or older” button to allow access to an online service.



Age verification

Please enter your date of birth
to verify your age

Enter

Fig. 1. Example of an honour system

These systems are, weirdly enough, not that secure. It is quite easy for any underage child to pretend that he or she is over the minimum age required to visit said online service. This defeats the purpose of having age verification at all.

¹ The Office of Communications

Another low-tech solution that was (and still is) used quite often is credit card verification. These systems are built upon the idea that credit cards are only issued to adults. This, however, is not a good system either, since a good portion of underage children can legitimately have a personal credit card [4]. Besides, a lot of credit card issuers have so-called “test card numbers” which are valid credit card numbers [8], security codes and expiry dates which (sometimes) can be used to access restricted content.

2.2 AI-Based Age Estimation Systems

First, a subtle clarification: there is a difference between age verification and age estimation. The first confirms the exact age of a user by cross-checking official documents and is extremely accurate but slower. In other words, age verification is actual proof. The latter (age estimation) is a smart guess of the user’s age; this does not give a definite answer like 23 years old, but most likely a range of 18-22 years old. The upside of age estimation is that it is really fast and relatively accurate, since there are not a lot of reasons to tell a 28-year-old and a 43-year-old apart, which makes it a relatively good option.

Age estimation is most often done by machine learning algorithms [20]. A very common approach is to, stay with me, use a deep neural network. This means that age estimation is done in roughly 4 steps [14]. The first step is the pre-processing of the image that is going to be estimated. This is not a set-in-stone practice and varies from deep learning model to deep learning model, but most of the time, this process contains cropping of the image, removing any colour in favour of black and white. When the pre-processing is done, is when the cool parts start; the face needs to be turned into mathematical values. There are 8 important “landmarks” on a human face that all have certain distances from each other, these are the mouth, cheeks, chin, eyes, nose and forehead. As people grow older, their face goes from round to more oval, so the length between the vertical landmarks can give a first clue to someone’s age. The third step is feature extraction, which means that the landmarks are examined more closely, wrinkles around the eyes, wrinkles on the forehead or cheeks that start to hang a little bit are all clues for a certain age group. The last step is giving a verdict on the age group the user is probably in. These groups could be something like < 16 , $16 - 18$, $19 - 30$, $30 - 50$, > 50 . These groups are arbitrary, since the model could be trained for different age groups; the full path is shown in figure 2.

This way of guessing the age of a user is quite fun, and a lot of studies are trying to make perfect age estimation, but this is not secure enough to give a green or red light for buying goods or accessing age-restricted services. That’s why the European Union introduced the following idea.

2.3 EU Digital Identity Wallet

The EU digital Identity Wallet is a product of the European Union, it’s created to “[create] a safe, reliable, and private mean[s] of digital identification for every-

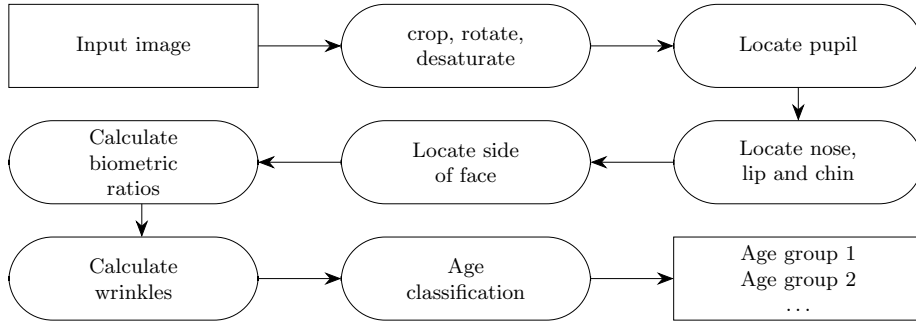


Fig. 2. Age recognition system block diagram (Adapted from [14])

one in Europe.” [6]. Although this app contains a lot of functionality regarding payments, education credentials, and travel documents, this report only focuses on the age verification solution of the EU. This solution, named the “Age Verification Solution” (very ingenious), is the EU’s way to block underage children from visiting sites that they are not supposed/allowed to visit. But this solution is also for validating age-related benefits, or purchasing age-restricted products like alcohol or tobacco in physical or online storefronts.

The Age Verification Solution works as a so-called ZKP, a zero-knowledge proof system [13]. This means that users cannot be linked to a physical person after initial identification. This prevents user profiling and tracking as a whole, which guarantees privacy security. The inner workings are neatly described by the European Union in the following step-by-step plan:

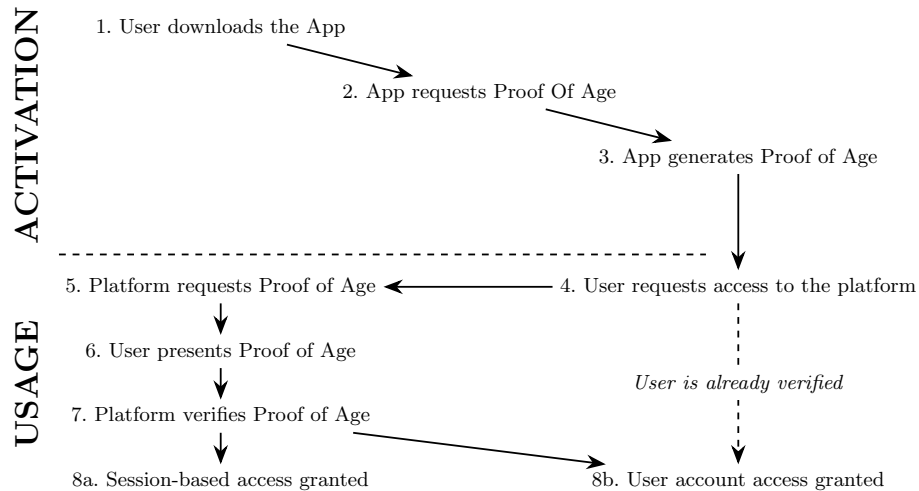


Fig. 3. Journey of a Proof of Age attestation user (taken from [13])

Activation As seen in figure 3, the app has an activation and usage part. The activation part starts with installing the application. After that, the interesting part starts. The user requests a proof of age certificate from the designated attestation provider. This mouthful of words means the same as: the user wants to verify their age. This is done via any allowed means of verification. The application supports various options like (1) national eIDs (like the Dutch DigiD), (2) using existing trusted databases that can assure age at the highest possible level, and (3) Know Your Customer, which is a required procedure employed by banks to check the identity of their customers. The last option is (4) document-based verification, which is a way confirmation is done via official identification like ID cards, passports, driver's licenses or any other official government-issued credentials. This does mean that the link between the document and the user needs to be verified; this can be done via "liveness checks" such as a selfie or short video.

When the age of a user has been verified, then the attestation provider may issue a certificate to the installed application (and only that instance). This certificate is then securely stored within the application and can be used to verify the age of the user without letting any third party know what the exact age of the user is or any other details about the user.

Usage When the user wants to access age-restricted content/services, that service can access Proof of Age. This can be done via Same-Device App integration, which means that the service requesting Proof of Age will open the age verification app. Another possibility is through the use of Cross-Device QR codes, where the requesting party displays a QR code that the user can scan with their mobile phone, and that will open the age verification app. After the user has the age verification app open, it will show basic details about the requesting party and whether or not the user wants to share details about being underage or not to said party. Assuming the user agrees, then the transaction proceeds, and the age verification app transmits the Proof of Age certificate to the requesting service. When the proof has been received, it is then checked against the attestation provider to test that this proof has not been forged. When this all checks out, and the user is allowed to use the service. The service may decide to make this a session, thus requiring the user to verify every time the service shall be used. An other option is saving the attestation to a user account, and thus saving the user from re-verifying every time the service is used.

technical details The application does, *after* the setup is complete (spoiler for 3) put a lot of protection on user data. The application is designed in such a way that the only data stored on the device is one or more attributes that state if a user is "age_over_18" or a similar attribute stating a different age. This is due to one of the design principles that the developers held onto [13]. The application also has cloning protection, that way the stored user data (I.E. the attribute(s)) are can not be used in an unauthorised duplication of credentials. This ensures

that copying credentials does not grant unauthorised parties access to services they would not otherwise have had.

Sadly this is only writting in the specifications of the application. As will be explored further in section 3, not everything made it into the end product created by the European Union’s development team.

3 Security and privacy risks

In this technological age, we get bombarded with hacks, data breaches and data leaks. 429 million social media account were hacked globally in 2025 [17] and hackers are getting smarter every day. This means that the security of our data should be the top priority of any software developer/designer. Sadly, this did not seem to be the case for our beloved EU Age Verification app. The app’s security features were able to be bypassed through simple steps that are definitely able to be reproduced with perseverance and a YouTube video [19,15]. It was

3.1 Handling of private data

The European Age Verification had a lot of problems before the source code became publicly available to everyone on github.com.

One such example of a violation of correct data-handling was written in `PassportLiveVideoViewModel.kt`, lines 169–190, commit `0bda457` [15]. This piece of code *should* handle what to do after a face-scan is done and returns a success, failure, or error state. When the face-scan returns a success state, the lossless PNG file of the user’s face is deleted, and the next screen is shown to set up the app further. When the user’s face does not match (enough), an error state is returned, which is then handled by showing an error to the user, but the temporary file is not deleted from the device, thus remaining vulnerable. The same happens when an exception (read unexpected error) occurs; the user is notified, but the image remains on the device without deletion. This way of handling data also conflicts with GDPR legislation, which states that requesting/processing of data identifying a natural person is only allowed when: “processed in a manner that ensures appropriate security of the personal data” [16]. Although this is not a catastrophic privacy breach, it does not spark trust in initiatives like this.

3.2 Protecting the Proof of Age

When the user sets up the account and thus sets up a PIN code to open the app, there is an attempt counter added to the “SharedPreferences” file, which is a settings file in which data is stored in plaintext. This counter is added to protect users from repeated checking of PIN codes, so an attacker can not just try every PIN code to gain access to the account. Sadly, this counter is not protected at all and allows the counter to be changed quite easily. The code for this can be found in `PrefsPinStorageProvider.kt`, lines 96–100, commit `5b32fe9` [15]. This means that when the maximum number of tries is reached, the attacker

can reset the counter back to zero and try some other combinations, effectively bypassing the security of the PIN code. To be fair, this is only easily done on “rooted” devices, but as stated in 3.4, this is not much of a protection either.

3.3 Integrity risks

Another risk was found in `ModelDownloader.kt`, lines 85–142, commit `0bda457` [15]. This piece of code downloads the face embedding model, which essentially checks if the face image embedded in the scanned document (ID, passport, etc.) matches the selfie to verify the document matches the user. But since the app allows the model to be fetched from the internet through HTTP, which is a less secure way to access resources on the internet. After the model is fetched, it is not checked through a checksum. This allows malicious actors to alter the original model in such a way that every check returns a positive result, thus making the selfie verification entirely dismantled.

3.4 Tampered-device detection

The application does not have any tamper detection for rooted devices or emulators. This means that any user can, without any form of obstruction, alter the files used by the age verification app. This is, as stated before, extra bad for tampering with devices that are not from the original owner. This way, a stolen phone can be rooted, and the verified attestation can be used. Although this does not seem very likely, it should be handled with care. As of the current latest version of the age verification app `6d97ea4`, this has not been fixed.

3.5 Dependency on non-European countries

As written in the introduction file about the Age verification app (`README.md`, lines 52–52, commit `b58c2cd` [15]), the app was supposed to implement “App and device verification based on Google Play Integrity API and Apple App Attestation.” This means that the application would call these API’s on Android and iOS through the Integrity API and App attestation, respectively. These make sure that the application is not using modified binaries, that the app is installed via the official Play/app store and that the device is a genuine Android/iPhone [7,5]. This, however, means that an application created by the European Union has to depend on technology from American Soil. This would strengthen the position of American (mega) corporations vis-à-vis the European Union.

Another statement written in the application specifications is the following: “An Age Verification App made available as a mobile application SHOULD be published on the App Stores for Android and iOS operating systems and MAY be published on other App Stores (e.g. Huawei, Samsung)” as stated in `architecture-and-technical-specifications.md`, lines 1055–1057, commit `5eb8a03` [15]. The SHOULD here states that the application must be published on the Google Play Store and the Apple App store, both of which need an

account for Google and Apple respectively. This means that a user that does not want to be linked to a mega-corporation like Google and Apple is not positioned in a situation where usage is possible.

The European self does not want to further deepen the dependency on American companies and the US government (or to be precise, companies and governments not in the European Union). A prime example is the Cloud Sovereignty Framework [12], which makes sure that data and infrastructure remain under the legal and regulatory control of the country or region where they reside (i.e. the European Union). For an upcoming European application that has to process personal data [16], it is not okay to be dependent on non-European countries and governments.

3.6 Reliability of the user

Since the Age verification setup process only requires a single step to prove that the user is over a certain age 2.3, this gives way to a well-known workaround: stealing an ID. The application does not check if the user is actually the same person whose ID was scanned. So if a child finds the wallet of a parent or caretaker, this means that the child can scan the ID, and that is enough evidence to prove the child unrestricted access to the internet with a perpetual attestation of “age_over_18” (or 21), meaning access to any service that would normally have been restricted.

4 Comparative analysis

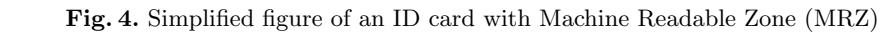
This section compares age verification approaches used in banking applications with the EU Digital Identity Wallet framework. Since European banks are required to comply with European standards, this is a great opportunity to compare with a prominent Dutch bank: Rabobank. Rabobank is active in 34 countries and has 2.4 million members in the Netherlands alone [1]. Comparison will be done based on the identity verification method, biometric usage, privacy protection, third-party dependencies and regulatory compliance.

4.1 Comparison criteria

Since banking apps and the Age Verification App have a similar goal when it comes to verifying the age of the user, a couple of banks will be compared against the main way of age verification through the European Age Verification App (document scanning) on the following criteria, as shown in the following list:

- (1) **Identity disclosure requirements:** Which personal attributes must be disclosed during verification,
- (2) **Verification method:** How identity or age is verified, including document scanning, biometrics, and liveness detection,
- (3) **Biometric processing:** Which biometric techniques are used and for what

4.2 Findings



The way the European Age verification App verifies the user’s age is through either optical character recognition of the machine-readable zones (MRZ), which are the 2 lines at the bottom of Figure 4 with the “<” (less-than) signs, by using the device’s camera. The second option would be through contactless NFC (Near Field Communication) communication with the chip that is in most identity cards and passports. The data is then verified using a checksum/data signature validation and by using cross-referencing with the issuing authority’s validation services.

Afterwards, the user has to do a live capture, which is either a selfie or video. This, let's say a selfie, is then matched with the document portrait, which has either been optically scanned in the first step, or been wirelessly transferred while scanning the document using the NFC chip. This portrait has to have a $\geq 98\%$ similarity score.

When the document is valid, official and matches the user who is trying to set up the Age Verification App. The birthdate is extracted from the MRZ written in YYMMDD format as shown on the second row, characters 14-19 in Figure 4.

The attestation is requested from the provider and saved on the device. This has all been defined by the Age Verification Specifications [13] section (3.3.2). The results are as follows:

	Age Verification App
Identity disclosure	All data on the NFC chip or machine-readable zone of a passport/ID-card.
Verification method	First document scanning, and later liveness detection.
Biometric processing	Facial matching of the user to the identity document.
Data minimisation	full name, sex, country, issuance data, and expiry date are only used to verify the document with the issuer. But scanning the data means either all or no data.
Third-party dependencies	Identity document issuing authority
Persistence of identity	No. After verification, only the attribute remains on the device.
Regulatory justification	TODO!!!=====
Privacy implications	See Section 3

Table 1. partial overview comparative analysis Age Verification App

Banks Since banks have to follow the anti-money laundering and combating the financing of terrorism laws created by the European Union [18]. Opening a banking account is very similar between banks. For the purpose of demonstrating how such a procedure mostly goes, ING has been chosen as an example. It is possible that, when opening a bank account, the steps are in a different order. The minimum, as required by European law, is described.

To open an ING bank account, firstly, a PIN code has to be created to open the application. This is a 5-digit code that has to be repeated. This is used to open the app and to confirm payments. Optionally, fingerprint and/or face recognition can be set up. Then the user's phone number for SMS-codes, and an email address used for tips and advertisements, when permission is granted.

After the "basic" data has been provided, the user is asked to scan the identifying document. The user is also forced to read how the data is used by the company and, if the user accepts, is then redirected to the page where the ID scan will actually happen. The user is asked to point the camera at the front of the ID card or passport to scan the MRZ. When the application accepts the

data, the device asks the user to scan the NFC chip on the document by holding the document against the back of the phone. If NFC scanning is not available, then the user is asked to take a picture of the front and back of the document. After the needed data is taken from the identifying document, the user is asked to take a scan of their face. The matching of face, document and person takes around 10 minutes.

After the break, the user is asked to provide their name, birthplace, issuance date of the ID, residence country, city, zip code and house number. The user is asked to go over all the data once more and check if everything is correct. The user is also asked to provide some information on how they plan to use the account and some financial data, but this is not interesting for this analysis [2,3].

	ING
Identity disclosure	All data on the NFC chip and machine-readable zone of a passport/ID-card, facial image, living address and financial data.
Verification method	Document photo + NFC scan and liveness detection.
Biometric processing	Facial matching of the user.
Data minimisation	No, due to regulations.
Third-party dependencies	Identity document issuing authority
Persistence of identity	Yes
Regulatory justification	TODO!!!=====
Privacy implications	After a possible cyber attack, personal data such as name and living address can be stolen by hackers.

Table 2. partial overview comparative analysis ING

All together

	Age Verification App	ING
Identity disclosure	All data on the NFC chip or machine-readable zone of a passport/ID card.	All data on the NFC chip and machine-readable zone of a passport/ID-card, facial image, living address and financial data.
Verification method	First document scanning, and later liveness detection.	Document photo + NFC scan and liveness detection.
Biometric processing	Facial matching of the user to the identity document.	Facial matching of the user.
Data minimisation	full name, sex, country, issuance data, and expiry date are only used to verify the document with the issuer. But scanning the data means either all or no data.	No, due to regulations.
Third-party dependencies	Identity document issuing authority	Identity document issuing authority
Persistence of identity	No. After verification, only the attribute remains on the device.	Yes
Regulatory justification	TODO!!!=====	TODO!!!=====
Privacy implications	See Section \ref{sec:security_risks}	After a possible cyber attack, personal data such as name and living address can be stolen by hackers.

Table 3. Total overview of comparative analysis**4.3 Differences****5 Technological proposal(s)****6 Ethical and societal considerations****7 Recommendations****8 Conclusion****References**

1. <https://www.rabobank.nl/over-ons/organisatie>
2. Als nieuwe klant een betaalrekening openen via de ing mobiel bankieren app, https://assets.ing.com/m/57082ca60caedd3b/original/ING_zo-word-je-klant-met-de-app-ing-betaalrekening-openen.pdf, accessed 26-05-2026
3. Betaalrekening openen mobiel bankieren app, https://assets.ing.com/m/60cefcda596d2cfa/1080p-Betaalrekening-openen_Mobiel-Bankieren-App.mp4, accessed 26-05-2026
4. Credit Cards for Teens: What to Consider — Chase — chase.com. <https://www.chase.com/personal/credit-cards/education/basics/children-credit-cards>, accessed 15-05-2026
5. DeviceCheck. <https://developer.apple.com/documentation/devicecheck>, accessed 21-05-2026
6. EU Digital Identity Wallet Home - EU Digital Identity Wallet - — ec.europa.eu, <https://ec.europa.eu/digital-building-blocks/sites/spaces/{E}{U}{D}{I}{G}{I}{T}{A}{L}{I}{D}{E}{N}{T}{I}{T}{Y}{W}{A}{L}{L}{E}{T}/pages/694487738/{E}{U}+{D}igital+{I}dentity+{W}allet+{H}ome>, accessed 12-05-2026
7. Play Integrity API — Android Developers — developer.android.com. <https://developer.android.com/google/play/integrity>, accessed 21-05-2026
8. Test card numbers — Adyen Docs — docs.adyen.com. <https://docs.adyen.com/development-resources/test-cards-and-credentials/test-card-numbers>, accessed 11-05-2026
9. (Oct 2008), <https://web.archive.org/web/20091202093822/http://www.ftc.gov/pri/protect/discretionary{\char\hyphenchar\font}{\}\vacy/coppafaqs.shtm>, accessed 11-05-2026
10. (Apr 2025), <https://www.congress.gov/bill/119th-congress/senate-bill/836>, accessed 11-05-2026
11. (Apr 2025), <https://www.gov.uk/government/publications/online-safety-act-explainer/online-safety-act-explainer>, accessed 11-05-2026
12. (Oct 2025), https://commission.europa.eu/document/download/09579818-64a6-4dd5-9577-446ab6219113_en, accessed 21-05-2026

13. Age verification technical specification (2026), <https://ageverification.dev/av-doc-technical-specification/docs/architecture-and-technical-specifications/>, accessed 12-05-2026
14. Dehshibi, M.M., Bastanfard, A.: A new algorithm for age recognition from facial images. *Signal Processing* **90**(8), 2431–2444 (2010). <https://doi.org/https://doi.org/10.1016/j.sigpro.2010.02.015>, <https://www.sciencedirect.com/science/article/pii/S0165168410000757>, special Section on Processing and Analysis of High-Dimensional Masses of Image and Signal Data
15. Digital Identity, E.: av-app-android-wallet-ui (2025), <https://github.com/eu-digital-identity-wallet/av-app-android-wallet-ui>, accessed 14-05-2026
16. European Parliament, Council of the European Union: Regulation (EU) 2016/679 of the European Parliament and of the Council, <https://data.europa.eu/eli/reg/2016/679/oj>, accessed 18-05-2026
17. House, N.: Social media hacking statistics [2026] (May 2026), <https://app.stationx.net/articles/social-media-hacking-statistics>
18. Joint Committee of the European Supervisory Authorities: Final report on draft joint regulatory technical standards on the measures credit institutions and financial institutions shall take to mitigate the risk of money laundering and terrorist financing where a third country’s law does not permit the application of group-wide policies and procedures. Final Report JC 2017 25, European Banking Authority (EBA), European Insurance and Occupational Pensions Authority (EIOPA), European Securities and Markets Authority (ESMA) (dec 2017), https://www.eba.europa.eu/sites/default/files/document_library/Publications/Draft%20Technical%20Standards/2017/JC%20RTS%20on%20the%20implementation%20of%20group%20wide%20AML-CFT%20policies%20in%20third%20countries%20/1035746/Final%20Report%20on%20Joint%20RTS%20on%203rd%20countries.pdf, accessed 27-05-2026
19. Marzolf, , O'Regan, E., Gkritsi, E.: Brussels launched an age checking app. hackers say it takes 2 minutes to break it. (Apr 2026), <https://www.politico.eu/article/eu-brussels-launched-age-checking-app-hackers-say-took-them-2-minutes-break-it/>, accessed 13-05-2026
20. Zaghbani, S., Boujneh, N., Bouhleh, M.S.: Age estimation using deep learning. *Computers Electrical Engineering* **68**, 337–347 (2018). <https://doi.org/https://doi.org/10.1016/j.compeleceng.2018.04.012>, <https://www.sciencedirect.com/science/article/pii/S0045790617334298>